

ENTERPRISE SECURITY ASSESSMENT LAB

AD NETWORK SECURITY METHODOLOGY REPORT

Phase 6 - Offline validation of service account password weakness

Report Section	Phase 06 - Kerberoast Hash Cracking
Project Area	Internal Network and Active Directory Security Assessment
Environment	Private Windows AD lab - Kali Linux, Windows Server, Windows endpoint
Prepared For	GitHub Portfolio Documentation
Document Type	Individual methodology PDF with redacted evidence

Authorized lab documentation only. Sensitive credential material, hashes, passwords, and replication output have been redacted before publication.

1. Executive Summary

This report documents **Kerberoast Hash Cracking** as part of the AD Network module in the Enterprise Security Assessment Lab. The section is written as a professional, portfolio-safe methodology report that explains the testing objective, workflow, evidence, tool usage, sanitized output, security risk, remediation guidance, and GitHub publication requirements.

Objective: Crack the requested Kerberoast ticket material offline to validate whether the service account password is weak in the private AD lab.

MITRE / Framework Mapping	T1110.002 - Password Cracking, in support of T1558.003 Kerberoasting
Testing Scope	Authorized private Active Directory lab only
Evidence Handling	Screenshots embedded with necessary redaction; raw hashes and secrets are not included

2. Methodology and Workflow

The methodology below is designed to show a controlled penetration-testing workflow rather than random tool execution. Each step supports a specific assessment goal and produces evidence that can be reviewed safely in a public portfolio.

- Use the Kerberoast hash file produced in the previous phase.
- Run Hashcat mode 13100 for Kerberos 5 TGS-REP etype 23.
- Validate only within the lab and avoid publishing raw hash material.
- Record sanitized evidence of the cracking result.
- Use the result to explain service account password risk and privilege exposure.

Command / Workflow Used

```
# Common Hashcat mode for Kerberos 5 TGS-REP etype 23
hashcat -m 13100 kerberoast_hashes.txt /usr/share/wordlists/rockyou.txt

# Show sanitized result locally only
hashcat -m 13100 kerberoast_hashes.txt --show
```

Sanitized Output Style

```
Hash type: Kerberos 5 TGS-REP etype 23
Status: Cracked in lab
Recovered material: <REDACTED_SERVICE_ACCOUNT_PASSWORD>
```

3. Evidence Mapping and Screenshot Explanation

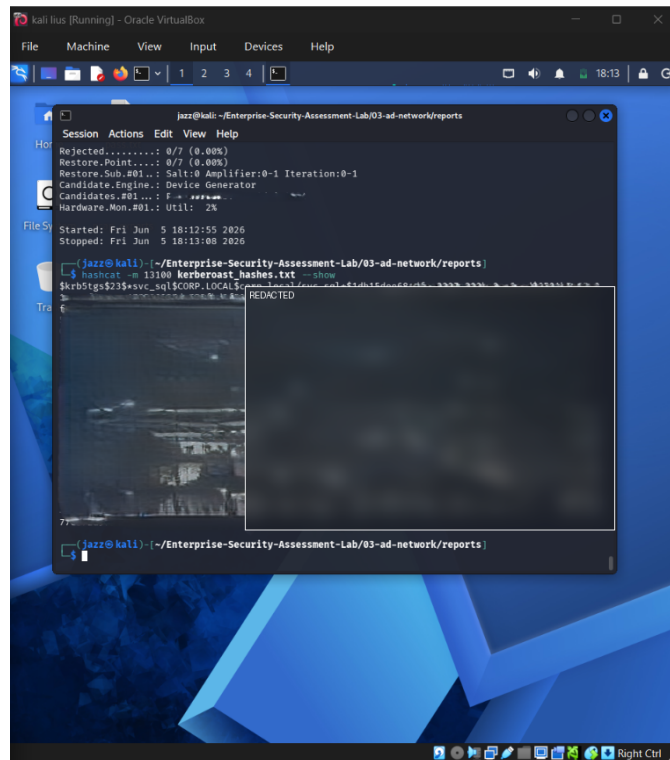


Figure - Kerberoast hash cracking evidence

This screenshot shows Kerberoast hash cracking in the lab. Sensitive hash and password output are redacted.

4. Technical Interpretation

The evidence is interpreted in the context of a private AD lab. The screenshot proves execution of the relevant technique or validation step, while the sanitized command and output blocks show how the result should be presented without exposing raw credential material.

What the evidence proves	The lab phase for Kerberoast Hash Cracking was executed and documented.
What it does not prove	It does not indicate testing of any public, third-party, or production network.
Publication status	Safe for GitHub after redaction of sensitive values.

5. Risk Analysis

A cracked service account password may provide access to databases, application services, or privileged domain paths. If service accounts are overprivileged, Kerberoasting can become a direct route to high-impact compromise.

Real-World Impact Categories

- Credential exposure or credential reuse risk
- Lateral movement or privilege escalation potential depending on account rights
- Domain visibility and attack path discovery in internal environments
- Operational and detection gaps if monitoring does not cover the relevant Windows, Kerberos, SMB, or LDAP events

6. Recommended Remediation

- Use 25+ character random passwords for service accounts.
- Prefer gMSA for supported Windows services.

- Rotate service account credentials.
- Reduce service account privileges.
- Monitor unusual TGS requests and high-volume ticket activity.

7. GitHub Redaction and Publication Guidance

- Publish only redacted evidence. Do not upload raw hashes, password material, ticket files, DCSync output, or secretsdump text dumps.
- Keep this report under 03-ad-network/reports/methodology/ and keep raw tool output in a private working folder unless fully sanitized.
- Use placeholders such as , , , and in public documentation.
- Confirm the screenshot file name in the README matches the repository file name exactly, including case, hyphens, and extension.

Do Not Upload

```
*.hash
*_hashes.txt
responder logs with raw NetNTLMv2
kerberoast_hashes.txt
secretsdump output
DCSync dumps
cracked-password files
unredacted BloodHound collection ZIPs if they expose sensitive names
raw command history containing passwords
```

8. Conclusion

The **Kerberoast Hash Cracking** phase demonstrates a structured and evidence-based AD testing workflow. The report explains the purpose of the test, shows sanitized evidence, connects the activity to real-world risk, and provides practical remediation guidance. This makes it suitable for a professional cybersecurity GitHub portfolio.